

Factor 1 — Response to Project Technical Approach

TAB A — Technical Approach

A.1 What we are inheriting, and what "done" means

HEC's decision to move authorization out of per-district Oracle Virtual Private Database policies and into the CWMS-Data-API (CDA) is the right one for a single cloud-hosted system, and the previous effort (W912HQ25P0049) produced a coherent design for it: a transparent proxy in front of CDA that resolves the caller's identity, asks Open Policy Agent (OPA) for a decision, caches it, and forwards the request to CDA with a single `x-cwms-auth-context` header that CDA's data layer turns into WHERE clauses on office, embargo, and sensitivity (PWS 1.2; ADR 0005, docs/source/decisions). We have read that design, the code that implements it, and the code that does not yet, and our technical approach starts from the specific state of the repositories rather than from the design on paper — because the two currently disagree.

Table A-1. The baseline as it stands in the repositories (verified August 2026).

Item	State	What finishing it requires	Task
cwms-data-api PR #1461 — AuthorizationContextHelper, AuthorizationFilterHelper, TimeSeriesController/TimeSeriesDao filtering, UserDao time-series-group privileges	Open since Nov 2025; 19 commits ahead of develop, 161 behind ; two of four schema-matrix CI legs and the OpenAPI static test failing; no approvals; unit tests only	Rebase onto develop; move header parsing into ApiServicelet after the authenticator as a context attribute (the November review comment); apply the office filter in the DAO, not only the controller; return 403 rather than 400 on office denial; make the feature flag runtime-toggleable; split the podman/Keycloak infrastructure commits into their own PR; add *IT integration tests that prove allow and deny	2
ADR 0006 and docs/source/access-management/** on develop	Marked "Implemented" and documents the helper classes — which exist only on the PR #1461 branch	Reconcile documentation with merged reality in the same PR series; until then the docs describe behaviour CDA does not have	2
cwms-access-management PR #13 (login bounce: token vs access_token; memoized auth context; compose parity)	Open since Feb 2026	Merge with the compose file de-duplicated (see below); replace the short-lived access-token pattern the author flagged as "not quite correct" with refresh handling	2
auth-contract issues — 136 open across sub-epics 3a–3k	Titles only, no bodies; created as a plan, not as a backlog	Triage in the first two development meetings into: done-by-code, superseded-by-this-PWS, still-open; close with a comment, or attach acceptance criteria. Issue #1523 ("PWS delivery audit") is the right frame and we will complete it	1a, 5a

Item	State	What finishing it requires	Task
Compose vs. podman drift — <code>docker-compose.podman.yml</code> and <code>Dockerfile.podman</code> exist only on the PR #1461 branch; the UI repo is built against that layout (external <code>cwmsdb_net</code> , CDA on 7001, Keycloak on 8080) while CDA's <code>docker-compose.yml</code> runs Keycloak on 8081 behind Traefik, uses office <code>q0</code> not <code>s0</code> , starts Keycloak deliberately <i>after</i> CDA, and defaults the management flag off	Two incompatible local stacks	One compose file per repository with profiles for the variants that have a reason to exist (Q&A 36: "single items of truth"); podman-specific files removed unless a podman-specific reason survives review	2
Three hard-coded sources of truth — request constraints computed in the proxy's TypeScript rather than in Rego; office→division map hard-coded in <code>helpers/offices.rego</code> ; embargo hours encoded in the time-series-group <i>name suffix</i> (<code>policy-dam_operator-r-72h</code>) after the <code>at_sec_ts_group_embargo</code> table was created and then dropped	None of the three is editable by a district administrator	Decide one home for each (Section A.2, Task 2) before building the UI that edits them	2
CDA principal cache, PR #1841 (<code>LruTtlMap</code> , open July–Aug 2026) and the proxy's Redis + in-memory decision cache	Two caches for overlapping data, neither with tests	One cache topology, defined in an ADR (Section A.2)	2, 3a
Rego tests	None (<code>opa</code> test coverage is zero); integration tests require five services and are documented as partially broken (Keycloak/DB username mismatch)	Policy unit tests with every persona and every deny path; integration-test fixture fixed	2, 5a

Two consequences follow. First, **the first thirty days are about landing what exists**, not adding to it; a proposal that started from "Task 2: build the UI" would be scheduling work on top of an unmerged foundation. Second, the effective authorization model today is the simple one the Government described in the Q&A — office plus role (`CWMS Users` may write, `TS ID Creator` may create identifiers, everyone else reads), enforced by `CdaAccessManager` and Oracle VPD — and **that model must keep working at every commit** while the policy-based model comes up behind a feature flag beside it.

A.2 Approach by task

Task 1a / 1b — Development meetings (PWS 2.1). Biweekly one-hour meetings with up to three of our staff relevant to the current work, and notes within one business day in the forms the PWS lists: typed minutes in Confluence, new or updated GitHub issues, milestones for intent, and skeleton pull requests with test names where a meeting produced a design decision. We treat the notes as the authoritative record for Task 5 approvals (Section A.2, Task 5) and as the running "PWS delivery audit". Our note template has four sections — decisions, work approved, blockers with owner, and next-meeting inputs — and every decision

that changes a design is also recorded as an ADR in `docs/source/decisions` so that other contributors can comment before acceptance (Q&A 46). Task 1b is priced as an additional 26-meeting quantity per Q&A 31.

Task 2 — Improve authorization and the web UI (PWS 2.1; TE1). Task B describes the UI work in detail. The sequence below is what makes the UI possible:

1. *Land PR #1461 behind the flag* (`cwms.dataapi.access.management.enabled`, made a `Togglz` feature so it can be toggled per environment without restart, consistent with how `USER_LISTS` is handled). The rebase includes the review items in Table A-1 and integration tests in the existing `DataApiTestIT` pattern using the `TestAccounts` persona users, with at least one test per persona that asserts a 403 and one that asserts filtered rows.
2. *Decide the three sources of truth and record them as ADRs.* Our recommendation, which we will bring to the first meeting with a written comparison: (a) **embargo** lives in the schema — reinstate `at_sec_ts_group_embargo(ts_group_code, embargo_hours)` from the previous effort's SQL, extend `av_sec_ts_group_mask`, and retire the name-suffix `regex (UserDao.EMBARGO_PATTERN, issue #1541)`, which resolves the open reviewer question on PR #1461 about where an office's embargo rules come from; (b) **offices and regions** are loaded into OPA through its data API from `cwms_office`, replacing the hard-coded map, on a refresh interval; (c) **constraints** move from the proxy's TypeScript into Rego so that a policy is one artifact, testable with `opa test`, and the proxy becomes a thin decision client. Each is a small, reversible change and each removes a place where district-editable data is currently a code edit.
3. *Expose the security primitives CDA lacks.* The CWMS schema already has everything the TE1 Policy tab needs — `at_sec_ts_groups`, `at_sec_ts_group_masks` (a LIKE pattern over `Location.Parameter.ParameterType.Interval.Duration.Version`), `at_sec_allow`, and the `cwms_sec` package procedures `assign_ts_masks_to_ts_group` and `assign_ts_group_user_group` — but CDA exposes none of it; the existing `/timeseries/group` endpoints are the data-categorization groups, not the security groups. We add `/auth/ts-groups/{id}`, `/masks`, and `/user-groups` controllers under `api/auth/`, registered in `ApiServlet.addUserManagementHandlers()` with the CWMS User Admins role, backed by `jOOQ` bindings to `cwms_sec` in the same style as the existing `CWMS_TS_PACKAGE` calls. District-scoped role administration uses the `POST/DELETE /user/{user-name}/roles/{office-id}` endpoints CDA already has and the management UI does not yet call.
4. *Build the UI increments in TE1 order* (Tab B), each as a work unit with tests, and the documentation and training materials as the last increment of the 180-day period.

The minimum successful product the PWS defines — an interface to manage access control, the access-control method working for time-series data, and documentation — is reached at the end of step 3 plus the first two UI increments; the remainder of Task 2 is breadth.

Task 3a / 3b — Stand up the authorization system in CWBI-Dev, then CWBI-Test (PWS 2.1; TE2).

CWMS-Data already operates inside the CWBI boundary as an ECS/Fargate module with an internal ALB, RDS Oracle, and Keycloak as the identity provider, defined in Python CDK (Q&A 37; CWBI standard-app pattern). We cannot create services; every infrastructure change is a Platform1 Jira issue to the CWBI infrastructure contractor, with the possibility of pull requests to the dev CDK (Q&A 11). Our approach is therefore to arrive at the first Platform1 ticket with the change fully specified:

- *Container placement.* The proxy, OPA, and cache run as additional containers in the CWMS-Data task definition — sidecars to CDA, sharing its task network — rather than as separate services. That keeps the `x-cwms-auth-context` header on a localhost hop, which matters because the header is unsigned (Section A.4). We will document the alternative (separate services behind path-based ALB listeners) in the same ADR with the cost and maintainability comparison Q&A 35 asks for, and recommend the sidecar layout unless CWBI's task-size limits force the split.

- *Cache.* CWMS is creating a Redis/Valkey cache in the environment for other needs (Q&A 35); we treat it as given, key the decision and user-context entries as the proxy does today, and retire the proxy's in-memory map and the CDA-side `LruTtlMap` so that there is one cache with one TTL policy and one invalidation path (user role change → `evict user:context:{username}`).
- *Images and health.* Hardened images per CWBI (Chainguard where an image exists; otherwise distroless or an image with a documented update path — Q&A 10), a `/health` endpoint on every container for CWBI's uptime monitoring (the proxy and OPA have them; CDA does not — we add `GET /cwms-data/health` so the target-group check stops depending on `/offices/HEC`), and the CWBI logo and consent banner on the management UI (TE2 Infrastructure).
- *STIG posture.* We self-assess against the Application Security and Development STIG and the Application Server STIG before each Dev deployment and keep the checklist in the repository; CWBI scans, we respond within the timelines in TE2, and the ISSO/ISSM asks for any ATO artifact through email or the Jira issue (Q&A 10, 37). No eMASS interaction, no on-site SCA, no travel (Q&A 12, 51).
- *Identity.* Keycloak with Login.gov or EAMS-A as CWBI directs (TE2 Infrastructure); CDA's `OpenIdConnectIdentityProvider` already consumes Keycloak JWTs, and the proxy's `decode-without-verify` shortcut is replaced with JWKS verification against the same well-known endpoint.
- *Definition of done.* Task 3a: a CWBI-Dev deployment where a persona user's request through the public FQDN is decided by OPA, cached, and filtered by CDA, with the flag on; the same request with the flag off behaves exactly as today. Task 3b repeats the promotion into CWBI-Test with the Test-environment configuration in the CDK environment YAML.

Task 4 — Load testing (PWS 2.1; TE3). Tab C.

Task 5a / 5b — Maintenance (PWS 2.1; TE4). Maintenance is a workflow with clocks, and we run it as one. A request arrives as a GitHub issue; we start within five days and submit a first work unit within two days of starting (PWS Task 5a). Classification takes up to one hour and ends with a status comment (bug — minor/routine/major; misuse; functionality gap) and an estimate; work over two hours waits for the approval label from the Technical POC, Technical Supervisor, or designee; a draft pull request is pushed after four hours of work regardless of completeness; every fix carries the description of the testing performed, and the monthly invoice references the issue with the six log fields the PWS requires (requestor, date, work-unit notes, issue status, fix description with tests, hours). Because the Government pays for delivered and accepted work units rather than in equal monthly amounts (Q&A 33), our maintenance staffing is fractional and elastic — a named associate engineer carries the steady-state load with a senior engineer behind him for major fixes — and weekly volume is tuned in the biweekly meeting against HEC's review capacity (PWS Rate of Work; Q&A 47). Scope is the repositories the Government named: `cwms-data-api`, `cwms-access-management`, and `cwms-database` primarily; `cwms-python`, `cwms-cli`, and `cwms-data-api-client` if a fix requires it; and upstream libraries through their own bug process with HEC's support (Q&A 46).

Work-unit discipline across every task. Pull requests are sized to HEC's review ladder — up to three files or 200 lines for a three-day review; up to ten files or 500 lines for five; anything larger for ten — and we prefer the first rung. Tests, or proof that existing tests cover the change, accompany every code change; new tools and helpers for loading test data follow the existing `defaultload.txt/timeseries.csv` fixture pattern; and the test-location preference order in the PWS (JUnit 5 unit tests, the JUnit 5 integration suite, anything repeatable locally, then anything repeatable on the build server) is the order we use.

A.3 Working with HEC, the CWBI-PMO, and other contractors

Three interfaces, three cadences. With HEC's Technical POC: pull-request review at the PWS ladder, the biweekly meeting, and a shared channel for same-day questions; we submit small units and we do not queue more than HEC can review in a week. With the CWBI-PMO: Platform1 Jira issues for every infrastructure change, written to their template with the standard-app diagram attached; response to scan results and

STIG-state requests inside the TE2 timelines; ISSO/ISSM artifact requests answered from the repository's security folder. With other contractors and USACE staff working in the same files: the Government's rule is that the first approved merge wins and the other party resolves the conflict (Q&A 46) — we rebase daily on `develop` to keep our side of that small, and anything beyond a source conflict goes to the next meeting or, if it cannot wait, to the Technical POC and COR the same day (PWS Coordination). Design-bearing disagreements become ADRs that all parties can comment on before acceptance.

Onboarding path (Q&A 11, 13, 19). Week 1: DD 7798 and DD 2875 for every named person, Public Trust initiation, the Platform1 access request, and delivery of Frasier Digital's fixed egress IP address to CWBI for bastion-host access **[FLAG: Joseph — confirm the static IP / fixed-egress arrangement before render]**. After kickoff: GitHub Enterprise repository access, expected within a day or two. Platform1: a week or more; bastion access: up to a month. None of that gates the first month of work: the CDA, access-management, and database repositories are public, the docker-compose stacks run on a laptop with the `gvenzl/oracle-free` image (Q&A 18), read access to the CDK is available immediately (Q&A 19), and the PR #1461 rebase, the ADRs, and the first UI increments are all local work. Our transition-in schedule (Factor 2, Tab C) shows the two tracks side by side.

A.4 The knowledge areas the Government will evaluate (instr. 3.2.1.1.1)

Full life cycle and agile practice. Two-week iterations aligned to the meeting cadence; a definition of done that equals an accepted work unit; every increment behind a feature flag until HEC turns it on; GitHub Actions as the build server — CDA's `build.yml` already runs the four-schema matrix, the integration tests, the OpenAPI static test, and the nightly ECR push through OIDC, so our CI additions (Rego tests, the k6 harness, the proxy's vitest suite) are steps in that workflow, not a parallel system. The TeamCity migration the PWS mentions is complete; only naming vestiges remain and we will remove them as we touch those files.

Database administration. CWMS is Oracle today and will migrate data to storage matched to its use (PWS 1.2); the authorization work must not deepen the Oracle dependency. Our Senior Oracle DBA owns the schema changes the design needs (the embargo table, the mask view extension, any `cwms_sec` procedure change), reviews the VPD interaction so that CDA-level filtering never contradicts a database-level policy, and keeps the integration-test images (`schema_installer:latest-dev`, `database-ready-ora-23.5`) current with the schema PRs in `cwms-database`. RDS-specific behaviour in GovCloud — parameter groups, the block-storage throttling the Government has observed under bursty writes (Q&A 38) — is part of the Tab C baseline.

REST API development. CDA is Javalin 4 with an `IdentityProvider` SPI and an `AccessManager`; the correct place for header parsing is the servlet's `before` chain, once, into a context attribute (the review comment on PR #1461), and the correct place for row filtering is the DAO. New endpoints ship with OpenAPI annotations so the static analysis test passes, and the API remains consumable by external clients (TE2 Data Exchange) — the `cwms-python` and JavaScript clients are among the repositories in scope.

Access-control mechanisms. Deny by default; OPA and the policy concept remain the decision point because further modules will integrate with it (Q&A 44); the policy model is `district` → `user group` → `time-series group` → `mask` → `privilege` → `embargo`, which is the CWMS security schema's own model, so the UI edits real rows rather than a parallel store. Authentication stays with Keycloak and CDA's existing providers (OIDC, API key, CAC where enabled). Tests prove both outcomes for every persona.

Configuration management. GitHub Enterprise for everything the Government funds; one compose file per repository; feature flags through Togglyz; ADRs for design changes; container base-image updates as a recurring maintenance work unit so that "reasonably easy to update libraries and images" (Q&A 10) is demonstrated, not asserted.

Cybersecurity, and communicating it succinctly. OWASP ZAP runs in CI against the compose stack on every pull request that touches request handling; the OWASP Top Ten review is part of our pull-request

template. Four specific weaknesses in the current baseline are closed in Task 2, and we state them here because the evaluators asked for the ability to communicate security needs succinctly: (1) CDA does not verify that `x-cwms-auth-context` came from the proxy, so anything that reaches CDA directly can forge or omit it — we sign the header with an HMAC shared between proxy and CDA (sidecar placement makes the key exchange local), and treat a missing header as deny when the flag is on; (2) the proxy honours an `x-test-user` impersonation header that is not gated by environment — removed outside test profiles; (3) the proxy decodes JWTs without verifying them — replaced by JWKS verification; (4) `BYPASS_AUTH=true` fails open — replaced by fail-closed with an explicit break-glass procedure. Audit records carry event type, time, source, outcome, and subject (TE2 Infrastructure), and are reviewed weekly during Task 5.

CWBI processes and requirements. Platform1 change requests; hardened images; health endpoints; the standard-app layout (Fargate service, internal ALB, RDS, Keycloak, WAF in front); secrets in Secrets Manager with ARNs in SSM; a minimal PMP with the standard-app diagram for our module (Q&A 48, 50); API registration in the CW Data Catalog (TE2 Metadata); no CUI or CDI in the work (Q&A 14).

A.5 Proposed level of effort per task (instr. 2.1.1)

Hours below reconcile exactly with Volume III and with the staffing plan in Factor 2, Tab A. No price information is included in this volume.

Table A-2. Level of effort by task and role (hours). [FLAG: reconcile with Vol III model before render]

Task	PM	Sr Oracle DBA	Sys Eng / Architect	Sr Forms (React) Dev	Sr Java Dev	Associate Engineers	Total
1a Dev elop ment meet ings (26)	78	8	12	12	12	8	130
2 Auth oriza tion + UI	50	30	—	220	150	100	550
3a CW BI- Dev stan d-up	40	—	120	—	40	—	200
5a Mai nten ance (≤80 3)	70	60	—	100	150	400	780
Base total	238	98	132	332	352	508	1,660

Task	PM	Sr Oracle DBA	Sys Eng / Architect	Sr Forms (React) Dev	Sr Java Dev	Associate Engineers	Total
1b Dev elop ment meet ings (opti on)	78	8	12	12	12	8	130
3b CW BI- Test stan d-up (opti on)	20	—	80	—	20	—	120
4 Load testi ng (opti on)	20	20	60	—	40	40	180
5b Mai nten ance (opti on, ≤704)	60	50	—	90	130	350	680
All- opti ons total	416	176	284	434	554	906	2,770

Task 5a and 5b hours are ceilings for planning; the Government's answer that payment follows delivered and accepted work units (Q&A 33) is reflected in the elastic staffing described in Task 5 above.